

Block 10 final software audit — 2026-09-28

Reviewer: Codex /root, keepkey-vault-v11-agent-3, with separate source and evidence reviews. Scope: Block 10 final readiness, confirmed by the owner during this round. This report supersedes the preparation packet for current source, findings and local evidence. Historical reports retain their original source identities.

Local remediation and targeted verification are complete at the source below. Final preflight and hosted qualification are recorded in the live readiness receipt with their exact head and run. Section 6 records Copilot reviews through Round 4; no clean review of this report revision or release acceptance is claimed.

1. Identity and finite scope

Item	Identity
Code-bearing PR	https://github.com/BitHighlander/keepkey-firmware/pull/876
Target	release/715-stack-09-base-for-10
Accepted adjacent base	ad7a3fe0d46b0cd6f8595b6c23b07933113a1424
Current code and tests	53c4d7c28cb13a0bd4fd785aa4db79d81c8f35ec
Round 2 reviewed source	24a9b41a38c210c7feb733d92061ad72c77ba085
Inventory generation predecessor	c6abf243eb8133bc82b7355c2c417e6847835bd7
Accepted Block 08	db7c711a6c824c42e7096d4867429bbe94cb6ffb
Local branch	audit/715-stack10-copilot-review-20260928
Pinned build image	sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2

The final containing report commit is recorded in the live receipt and PR description. Work uses the isolated repository /private/tmp/kk715-block10-review-20260928. No Block 11–13 implementation is included in this round. This is an audit unit; no assembled release branch is updated.

Dependency	Exact pin
code-signing-keys	a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec
deps/crypto/trezor-firmware	8a392f70a5d5575ece3dfb35f115d4a4b27f497c
deps/device-protocol	5fec9e6906a340be5eb3d795ec746769065b2db8
deps/googletest	7888184f28509dba839e3683409443e0b5bb8948
deps/python-keepkey	41af909341965c81b8afadd38f299d6f929089af
deps/qrenc/QR-Code-generator	6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8
deps/sca-hardening/SecAESSTM32	71d356a1141624994cf613bd2d2583892e8e6d5a

Canonical SOP SHA256: cd2c546d41f0a723f6ce84199a3fb03661f79ab3f49fbafca08de96a7c309e89. Canonical master SHA256: a0fc0bd261fe89515a02a4162ce649919cc50936a6f53301ece743fea24c1a07.

2. Current-source reconciliation and finding dispositions

Finding	Disposition and evidence
Original unknown-token disclosure	Preserved: contract, recipient/spender and complete uint256 raw base units are reviewed. Amount overflow refuses; AdvancedMode, raw-data confirmation and unlimited-approval refusal remain. Native and wire assertions execute.
INT-09-002 malformed authenticator slot	Preserved: checked decimal parsing precedes lookup. Native and both-product Ping contracts reject malformed/overflow aliases; valid lookup remains available.
Copilot round 1 report omission	Fixed in 24a9b41a: report requires named Block 9/10 cases and expected variant outcomes. This round also requires the new ninth Block 10 case.
Copilot round 1 padded-zero account value	Fixed in 24a9b41a: classifier treats empty and padded zero equivalently before account routing. The original defect incorrectly rejected equivalent encodings; no signing bypass was established.
B10-R3-01 account calldata length mismatch	Fixed in 53c4d7c28: any account-transfer calldata must be a complete canonical 68-byte ERC20 transfer before confirmation or derivation. Initial chunk and declared total can no longer disagree across routing and signing.
B10-R3-02 stale readiness evidence	Closed by this current source/PDF inventory, hash-bound local evidence and final live receipt. The earlier four-page report is a preparation checkpoint, not current verification.

B10-R3-01 is inherited from the predecessor and directly affects the account-routing path audited here. On 24a9b41a, a canonical 68-byte initial transfer with declared length 69 signed after streaming one extra byte, while the same 69 bytes supplied initially were rejected. For a known token the first screen described a standard token transfer; the later signer used generic calldata classification. AdvancedMode, fee and complete calldata-hash consent remained enforced. No signature without consent or fund theft is demonstrated. Some invalid shorter/zero/absent totals also displayed an account confirmation before eventual rejection.

The original binary is identified in the evidence. The new regression failed five subtests against it. The repaired binary passes all ten malformed cases (known DAI and unknown token, each with inline suffix, streamed suffix, short, zero and absent total), with zero button requests and a matching canonical signature on retry. Ordinary external transactions still permit the existing AdvancedMode/raw-data fallback, now checked for streamed trailing bytes too. Native account transfers with omitted versus explicit-empty calldata retain identical signatures.

The separate remediation review found no additional actionable defect. It checked protobuf zero defaults, valid native transfers, canonical token transfers, padded zero, rejection timing and the new report requirement. No test identity was removed and no dependency pin changed.

3. Security closure and consumer coverage

State/origin, observer and phase	Allowed and forbidden outcomes	Executed assertion or limit
Host ERC20 bytes; user display; full signing	Show exact unknown contract, counterparty and raw amount. Refuse truncation or aliasing.	Native bounded-buffer and uint256 tests; wire zero/one/maximum amounts, contract substitution and signature differences. Historical maximum-value pixel capture is carried forward because formatter/layout code is unchanged.
Host account path and calldata; display/signature; full routing	Derived recipient must match; only canonical complete token calldata reaches account consent.	Nine-case wire module includes ten malformed total cases, wrong destination, padded zero and valid retries. New test fails on old firmware.
Wire native value; classifier, display and signature; full	Omitted, empty, one-zero and 32-zero encodings agree. Nonzero value cannot masquerade as a zero-value token transfer.	Independent probe covers ordinary/account paths, one and padded-one values; existing signature-equality regressions cover zero forms.
Host calldata and policies; user/host; full signing	Preserve raw-data and AdvancedMode requirements, refuse unlimited allowance, emit no signature after cancellation.	Wire malformed split/trailing/address data, disabled policy, unlimited approval, cancel on each review button and retry.
Host slot text; host response; both variants	Reject malformed/out-of-range aliases without account identity or success; valid lookup remains.	Native AccountSlotRejectsNumericAliasesBeforeLookup and dedicated Ping contract, both products in hosted baseline and required in final matrix.
Host typed-array dimensions; parser/digest; full	Enforce fixed dimensions outermost first and at inner levels; preserve valid dynamic arrays.	Native FixedDimensionsAreCheckedOutermostFirst and InnerDimensionsAreCheckedToo; Python caller uses the same written-order convention. Implementation is inherited, with direct added test coverage.
JUnit inputs; report consumer; both products	Missing, empty, duplicate, failing or wrongly skipped required evidence must fail closed.	18 report-gate regressions; new case in exact full-pass/BTC-skip contract set; final artifact identities checked independently.

Bitcoin-only excludes EVM signing and records the exact reason for all nine Block 10 cases. The authenticator contract executes in both products. Full/BTC skip identities and reasons are retained in hosted XML and manifest; skipped work is not counted as passed. No physical-button, physical power-cycle or on-device display execution is claimed by emulator evidence.

4. Verification and provenance

Check	Source / result / evidence
Original failing control	24a9b41a binary; new regression fails five subtests. Independent known/unknown streamed-tail probe signs while initial-tail refuses.
Fixed focused wire	53c4d7c28 source; nine tests and ten malformed subtests pass, including cancellation/retry and preserved generic fallback.
Native account compatibility	Fixed source; omitted versus explicit zero/empty calldata both sign, with identical signatures.
Local full native	Fixed source; 669/669 pass in a fresh working directory, with raw XML in evidence. Earlier reused-storage run failed a Recovery initialization precondition and is preserved separately.
Report gate and Stage 1	18 report tests plus shared preflight tests; final full preflight result and log are in the live receipt.
Prior hosted baseline	CI 36379501181 at 24a9b41a: all required jobs passed. Full native 669/19/18; BTC 143/19/18. Full merged report 1519 pass, 84 skips, zero failures/errors. This is prior-source evidence, not a run of the new repair.
Prior artifact verification	Both ARM manifests and all 46 files verified; PDF/merged XML/contract hashes matched; 1347 OLED frame and 194 sequence hashes verified. Block 10 maximum-value pixels use explicitly historical captures.
Final hosted matrix	Completed after the material repair: exact PR head, full/BTC native and wire, both ARM/resource variants, report and evidence gates. Outcomes for later documentation-only heads are recorded by SHA in the live readiness receipt.

Local evidence archive: docs/release/audit-units/715-10-final-audit-20260928.tgz. Archive SHA256: 93887e0012274c6ecdc912bfe57a6d90c6b13323635c2ab339ed78a24d66ddc. Each archived file is listed and hashed by evidence-index.json inside the archive. It contains probe source/results, old failing regression, repaired wire/native results, source identity and baseline artifact verification. Test fixtures use the public test mnemonic. Prior historical artifacts are not relabeled as fresh executions.

5. Complete adjacent Git inventory

Reproduce the committed range with git diff --numstat ad7a3fe0d46b0cd6f8595b6c23b07933113a1424..c6abf243eb8133bc82b7355c2c417e6847835bd7. The initial report creation adds the source/PDF/evidence paths shown below; the final freeze uses an immutable containing predecessor and verifies the complete final diff against this table. Binary paths have no text counts. Counts include tests, workflow, reports and evidence; overlapping historical commit counts are not added as unique changes.

Added	Deleted	Path
1	2	.gitattributes
1	1	.github/workflows/ci.yml
203	0	docs/release/audit-units/715-08-10-integration-20260927.md
-	-	docs/release/audit-units/715-08-10-integration-20260927.pdf
-	-	docs/release/audit-units/715-08-10-local-evidence-20260927.tgz
163	0	docs/release/audit-units/715-10-audit-20260927.md
-	-	docs/release/audit-units/715-10-audit-20260927.pdf
31	0	docs/release/audit-units/715-10-completion-plan-20260927.md
125	0	docs/release/audit-units/715-10-final-audit-20260928.md
-	-	docs/release/audit-units/715-10-final-audit-20260928.pdf
-	-	docs/release/audit-units/715-10-final-audit-20260928.tgz

Added	Deleted	Path
-	-	docs/release/audit-units/715-10-final-readiness-evidence-20260927.tgz
73	0	docs/release/audit-units/715-10-intake-20260927.md
48	0	docs/release/audit-units/715-10-reconciliation-20260927.json
4	0	include/keepkey/firmware/ethereum.h
3	7	lib/firmware/authenticator.c
64	15	lib/firmware/ethereum.c
21	10	lib/firmware/fsm_msg_ethereum.h
14	0	scripts/emulator/python-keepkey-tests.sh
36	0	scripts/emulator/test_stack09_integration.py
201	0	scripts/emulator/test_stack10_regressions.py
25	0	scripts/generate-test-report.py
18	0	unittests/firmware/authenticator.cpp
64	0	unittests/firmware/eip712_stream.cpp
110	6	unittests/firmware/ethereum.cpp

The 24a9b41a review repair changed three files, adding 54 and deleting 2 lines. This round's 53c4d7c28 repair changes three files, adding 48 and deleting 2 lines. Earlier implementation/integration commits and their historical inventories remain documented in 715-10-audit-20260927.md and 715-08-10-integration-20260927.md. Current adjacent totals are derived from the table, not summed across those overlapping commits.

6. Review status and final-audit boundary

Review history as of 2026-09-28T21:08Z: three initial Copilot requests and one additional owner-authorized request were registered. Round 1 (5334005758) found two issues, fixed in 24a9b41a. Round 2 (5334271834) had Findings: None on that older source. Round 3 (5344280099) found a documentation-spacing issue, fixed in 8c8f7a0c5. Round 4 (5344669790) reviewed 8c8f7a0c5 with zero inline findings but a body-only packet-provenance finding, corrected here. The live PR and canonical budget ledger govern later review status.

This report revision follows Round 4, so that review is historical; no clean review of this final head is claimed. Final review readiness requires the frozen packet, passing exact-head preflight and hosted CI, zero known open in-scope findings, and authorization for any further request. Local verification, external delivery and release acceptance remain separate statuses.

For the combined release, Block 11 must incorporate the repaired Block 10 source and close its own reopened findings; Block 12 and final Block 13 integration remain separately owned work. These are dependency notes, not work performed or accepted here. Physical-device checks, assembled release qualification, merge and publication remain outside Block 10 local software acceptance.